Technical Whitepaper - Secure and Decentralized Retrofit for Industrial IoT Devices

Date: november 8, 2026
Author: Tiziano Ciccone
Version: 0.5
Status: Technical draft for discussion
Maturity: This document describes an architecture at concept stage (TRL 3-4). The latency metrics and budgets reported are design targets, not experimental results. No prototype validation has yet been conducted.
Document license: CC BY-SA 4.0
Reference firmware license: Apache-2.0
Reference hardware license: CERN-OHL-S-2.0
Scope: Monitoring, alarming, and command authorization for industrial IoT devices (refrigeration plants, cold rooms, warehouses, machinery with multi-parameter telemetry), both new and existing.
Language: In case of interpretive discrepancy between the Italian and English versions, the English version prevails.

---

1. Problem and Objectives

Existing industrial IoT devices, such as controllers for refrigeration plants, cold rooms, and warehouses, exhibit three recurring critical issues:

1. **Data trust.** Telemetry (temperature, humidity, door status, current draw, pressures, alarms, defrost cycles, etc.) transits through centralized controllers and brokers: a single compromised point can alter or erase the data history.
2. **Weak command authorization.** Changes to setpoints, duty cycles, alarm thresholds, or operational parameters often rely on shared credentials, with no immutable audit trail and no verification of the integrity of the executing device.
3. **Alarm latency.** Cloud-first architectures introduce WAN connectivity dependency into the critical alarm path.

Project objectives:

Objective	Acceptance Metric
O1 - End-to-end open source	Firmware, hardware, specifications, and toolchain under OSI licenses
O2 - Low cost	Sensor Tag < $20 BOM; Bridge < $100 BOM

Objective	Acceptance Metric
O3 - Retrofit and new plant coverage	Hardware profiles with common firmware
O4 - Fast authentication and commands	Fast-path command < 100 ms
O5 - Fast alarms	Detection→local notification < 1 s; peer propagation < 200 ms
O6 - Decentralized and encrypted data	No mandatory central server; E2E encryption
O7 - Reduced patent risk	Documented design-around + defensive publication
O8 - Data generality	Arbitrary multi-sensor payload, not just temperature

---

2. Alignment with Reference Frameworks

The project is designed in alignment with the principles of **IEC 62443** (zone and conduit segmentation, least privilege, defense in depth) and **NIST SP 800-82** (security of industrial control systems). The separation between the data plane and the command plane, the use of secure elements and TPMs as root of trust, and controlled local degradation are choices traceable to these frameworks; this document does not, however, constitute a certification of conformity.

For semantic interoperability, the payload schema is designed to be mappable onto **EPCIS 2.0** (supply-chain events) and **OPC UA** (industrial interoperability); the implementation of such mappings is the subject of subsequent development phases.

---

3. Design Principles

- **P1 - Edge-first safety.** Safety and alarm functions do not depend on the network or the blockchain. The blockchain is outside the critical path.
- **P2 - Sign at the source.** Every measurement is signed by the device that produces it before leaving the sensor.
- **P3 - Two separate planes.** The data plane (telemetry, alarms) and the command plane (authorization) have different requirements and technologies and do not share the critical path.
- **P4 - Separation of authority/identity.** Identity is cryptographic and hardware-rooted; authorization is expressed in smart contracts and verified locally.
- **P5 - Controlled degradation.** If the WAN fails, the site continues to monitor, alarm, and authorize locally; the chain re-synchronizes afterwards.
- **P6 - Legacy compatibility.** Standard interfaces (Modbus RTU/TCP, BACnet MS/TP, dry contacts, 4-20 mA, I²C/SPI/UART) as first-class citizens.

- **P7 - Generic payload.** The data format is extensible: any sensor or quantity can be represented without modifying the signing and transport protocol.

---

4. Layered Architecture

Synthetic flow:

1. L0→L1: sampling and ECDSA signing in the secure element.
2. L1→L2: transmission over mesh (Thread/BLE) or bus (Modbus/BACnet/I²C/SPI).
3. L2: local rule evaluation, alarm emission, encryption, P2P gossip.
4. L3: aggregation, hourly Merkle anchoring to L5, storage on L4.
5. L5: authorizes commands and preserves the immutable audit trail.
6. L6: users independently verify headers and proofs.

---

5. Hardware Profiles

Profile	Target	Key Components	Indicative BOM
Tag	Battery-powered retrofit sensor	Low-power MCU + I²C secure element + sensor interface (I²C/SPI/1-Wire/analog) + mesh radio	$8-18
Bridge	Per machine or group of machines	Powerful SBC/MCU + TPM 2.0 + border router radio + bus interfaces (RS-485, Ethernet)	$40-95
Site Node	Warehouse / site	Industrial SBC + NVMe + TPM/HSM + UPS	$200-450
Native Module	New devices (OEM integration)	MCU + secure element + TrustZone, identical firmware	$10-25 at volume

Common technical choices:

- **Root of trust:** ECDSA P-256 secure element for Tag and Native; TPM 2.0 for Bridge and Site Node. The Bridge TPM is used for periodic attestation and for signing anchoring transactions (once per hour), not for signing every single telemetry record.
- **Secure boot + flash encryption** mandatory on all MCU-based profiles.
- **Single core firmware** with per-profile feature flags: same signing, attestation, and protocol code; only drivers and policies change.

- **Capability negotiation:** the Tag declares its resources (battery, radio, sensors, actuators); the Bridge assigns its role (e.g., a Tag becoming a mesh relay when powered).
- **Hardware upgrades without software forks:** adding a more capable profile enables functions (full validator, storage) without changing the data contract.

---

6. Identity, Root of Trust, and Attestation

6.1 Device Identity

- Key pair generated **inside** the secure element at manufacturing time; the private key is never exportable.
- Decentralized identifier `did:key` (or `did:pkh`) derived from the public key; optional X.509 certificate for enterprise interoperability.
- On-chain registration: public key hash + metadata (model, site, date) in a registry contract.

6.2 Attestation

- **Measured boot:** firmware and configuration hashes measured at every boot.
- **Attestation report** signed by the device key, containing: firmware measurement, anti-rollback counter, challenge nonce, secure boot state.
- **Verification:** the Bridge (and periodically the contract) verifies the report against the expected measurement published on-chain by the maintainer.
- **Periodic attestation** (e.g., every 15 min) to detect compromised or tampered devices.
- **Time synchronization:** between Tag and Bridge occurs via NTP or PTP; clock drift is monitored and corrected before Merkle anchoring.

6.3 Key Management

- Key rotation supported by contract: new key signed by the old one + on-chain authorization.
- Revocation: on-chain revocation list consulted by the Bridge and peers; a revoked Tag can no longer sign accepted commands.
- Decommissioning: key deletion in the secure element + on-chain revocation event.

---

7. Data Plane: Decentralized Multi-Parameter Telemetry

Pipeline:

1. **Sampling** (Tag): configurable interval per sensor; payload defined by an extensible schema (JSON/CBOR) admitting arbitrary quantities (temperature, humidity, state, currents, pressures, vibration, counters, events).

2. **Source signing:** every record is ECDSA-signed; includes a monotonic counter (anti-replay) and device timestamp.
3. **Local buffer:** ring buffer on flash with overwrite policy and journal.
4. **E2E encryption:** AES-256-GCM with a site key; the Bridge cannot read the payload unless authorized (capability).
5. **IPFS publication:** content-addressed block → CID.
6. **Anchoring:** every hour the Bridge computes the Merkle root of the period's CIDs and writes it on-chain.
7. **Access:** authorized users receive a UCAN capability enabling decryption and CID retrieval.

Properties: no central server owns the data; integrity is mathematically verifiable; the chain contains only hashes (no personal or commercial data). The payload schema is versioned and open, so new sensor types do not require protocol changes.

---

8. Command Plane: Fast Authorization

The requirement of "maximum security and maximum speed" is resolved with **two paths**.

8.1 Cold Path (On-Chain Authorization)

1. The operator authenticates (MFA/SSO) and signs a *command envelope*.
2. The contract verifies: role, device state, valid attestation, site policy.
3. The contract emits an authorization event with nonce and expiry.
4. The Bridge verifies the proof (header/event) via light client and forwards the command to the Tag.
5. The Tag verifies signature, nonce, and expiry in the secure element, then executes.

Typical latency: 1-4 s (consensus-dominated).

8.2 Hot Path (Pre-Authorized Session Ticket)

For frequent, repetitive commands (setpoints, cycles, alarm silencing, operational parameters):

1. Once per session, the contract authorizes a **session ticket** (PASETO v4.public or biscuit) with: scope, target device, permitted parameters, short expiry (e.g., 15 min), usage limit.
2. The ticket is held by the Bridge and the client.
3. Subsequent commands travel as a **signed envelope + ticket**, verified locally by the Tag without touching the chain.
4. The Bridge submits an on-chain **batch summary** of executed commands every N minutes, for audit purposes.

Typical latency: 30-90 ms. Hot-path latency is dominated by cryptographic verification time in the Tag's secure element; the stated value is a target that assumes firmware and I²C interface optimization.

Hot-path security: the ticket is scope- and time-limited; the anti-replay counter is in the secure element; ticket revocation is possible on-chain and propagated to Bridges within seconds; every execution is logged locally and anchored in batches.

8.3 Non-Negotiable Safety Rules

- No command may violate the **physical safety limits** encoded in the firmware (e.g., permitted range for each parameter, maximum cycle duration, minimum alarm thresholds).
- Commands that modify safety always require the cold path.
- Dual authorization for critical operations (e.g., disabling a critical alarm).

---

9. Alarm Plane: Edge-First, P2P

Detection and propagation chain:

1. **Local evaluation** (Bridge or Tag, depending on profile): windowed rules with hysteresis over any payload quantity (e.g., T > threshold for 10 min, abnormal current, door open, pressure out of range).
2. **Immediate local alarm:** relay/siren/dry contact on the Bridge. No network required.
3. **Publication on a priority topic** via GossipSub (libp2p): signed, encrypted message with TTL and priority.
4. **Peer propagation** (other Bridges on site and at neighbouring sites) in < 200 ms on LAN.
5. **User notification:** WebRTC/WebTransport to connected clients; push relay for offline clients; SMS/e-mail fallback via local gateway.
6. **Asynchronous anchoring:** the event is included in the next Merkle batch (2-10 s), outside the critical path.

Latency budget:

Leg	Target
Sensor → signature	20-100 ms
Signature → rule evaluation	10-50 ms
Detection → local actuator	< 500 ms
Bridge → peer (LAN)	20-100 ms
Bridge → client notification	200-800 ms
On-chain anchoring	2-10 s (asynchronous)

Architectural rule: the alarm is emitted locally by the Bridge or Tag based on rules encoded in the firmware. The blockchain receives the event only later, for audit purposes, and cannot delay or block its emission.

---

10. Security: Threat Model and Countermeasures

Threat	Countermeasure
Physical tampering with the Tag	Secure element, opening detection, non-extractable key
Malicious firmware	Secure boot, flash encryption, signed OTA, anti-rollback
Command replay	Monotonic counter in the SE + nonce + ticket expiry
MITM on the mesh	Noise Protocol (IK/XX patterns), authenticated sessions
Bridge compromise	Periodic attestation, least privilege, network segregation
Cloned device	Nonce-based attestation, on-chain registry, revocation
WAN connectivity loss	Local degradation: monitoring, alarms, and tickets remain operational
Unauthorized data access	E2E encryption, UCAN capability, per-site keys

Cryptography: ECDSA P-256 (signing), ECDH P-256 (key exchange), AES-256-GCM (payload), SHA-256 (hashing), Noise (P2P transport).

---

11. Essential Lifecycle Steps

11.1 Factory Provisioning

1. Key generation in the secure element.
2. Writing of the certificate/identity and model.
3. Secure boot and flash encryption enabled and verified.
4. Registration of the public key hash in the registry (offline or on-chain).
5. Labelling with a QR code containing the DID.

> **Supply-chain note.** The factory provisioning process and key handling during manufacturing will be the subject of a separate procedure, including controls against counterfeit component injection and BOM integrity verification.

11.2 Installation and Pairing

1. QR scan by the Bridge.
2. Noise handshake: the Tag verifies the Bridge's identity, the Bridge verifies the Tag's attestation.
3. Assignment to site and machine; definition of rules and payload schema.
4. Distribution of the site key (encrypted for the Tag).

5. First signed and anchored record.

11.3 Operation

1. Continuous sampling and signing.
2. Local rule evaluation and alarms.
3. IPFS publication and hourly Merkle anchoring.
4. Periodic attestation.
5. Batch command audit.

11.4 Commands

1. User authentication and envelope signing.
2. Cold or hot path (section 8).
3. Local verification in the secure element.
4. Execution and logging.
5. Audit anchoring.

11.5 Firmware Update (OTA)

1. Manifest signed with the release key.
2. Distribution via IPFS (CID in the manifest).
3. Signature and hash verification on the device.
4. Write to B partition and reboot with automatic rollback on failure.
5. Update of the expected measurement in the registry.

11.6 Rotation and Revocation

1. New key generated in the SE.
2. Rotation transaction signed by the old key.
3. Revocation propagation to Bridges and peers.
4. Registry update.

11.7 Decommissioning

1. Key deletion in the SE.
2. On-chain revocation event.
3. Anonymization of site metadata.

---

12. Interoperability with Existing Systems

- **Modbus RTU/TCP and BACnet MS/TP:** the Bridge acts as a gateway, reading standard registers and objects and mapping them to signed records.
- **Dry contacts, 4-20 mA, I²C/SPI/UART:** direct interface for legacy sensors and actuators.
- **Existing controllers:** no replacement required; the project overlays as a trust and audit layer.
- **MQTT:** supported as an optional adapter, never as the critical path.
- **Open payload schema:** new sensor types or quantities are added via versioned extensions, without modifying signing and transport.

---

13. Validation and Next Steps

Subsequent phases will involve experimental measurement of the stated latencies, total cost of ownership (TCO) analysis, and verification of the EPCIS 2.0 and OPC UA mappings on a pilot installation.

Proposed pilot success criteria:

- Hot-path latency ≤ 100 ms (p95) over 10,000 commands.
- Alarm propagation to peer ≤ 200 ms (p95) on LAN.
- Verifiable integrity of 100% of anchored records.
- Full operation under WAN degradation for at least 72 consecutive hours.

Appendix A - Telemetry Record Structure (Multi-Parameter Example)

The `fridge.v1` schema is an example; other domains use different identifiers (e.g., `pump.v1`, `hvac.v1`) with the same envelope structure.

```
{
  "v": 1,
  "did": "did:key:z6Mk...",
  "site": "sha256:...",
  "seq": 1048577,
  "ts": "2026-11-08T09:14:22Z",
  "schema": "fridge.v1",
  "data": {
    "t_c": -18.42,
    "rh": 71.2,
    "door": 0,
    "compressor_current_a": 4.12,
    "defrost_active": false,
    "pressure_bar": 2.31
  },
  "prev": "sha256:...",
  "sig": "ecdsa-p256:..."
}
```

Appendix B - Command Envelope Structure

```
{
  "v": 1,
  "cmd": "set_setpoint",
  "target": "did:key:z6Mk...",
  "params": { "t_c": -20.0 },
  "nonce": "0x9f3a...",
  "exp": 1762590000,
  "ticket": "paseto-v4.public:...",
  "issuer": "did:key:z6Mk...",
  "sig": "ecdsa-p256:..."
}
```

Appendix C - Blockchain Selection Criteria

- **Permissioned** (e.g., Hyperledger Besu/Fabric) if the consortium controls validators and requires predictable throughput.
- **Public L2** if public verifiability and censorship resistance are required.
- Minimum requirements: efficient light client, finality < 5 s, negligible anchoring costs, Merkle proof support, stable APIs. Cold-path latencies (1-4 s) refer to a permissioned blockchain or a fast-finality Layer-2; using a public mainnet would entail higher latencies and non-negligible gas costs.

© 2026 Tiziano Ciccone. This document is released under the CC BY-SA 4.0 license.

End of document - v0.5 (EN)